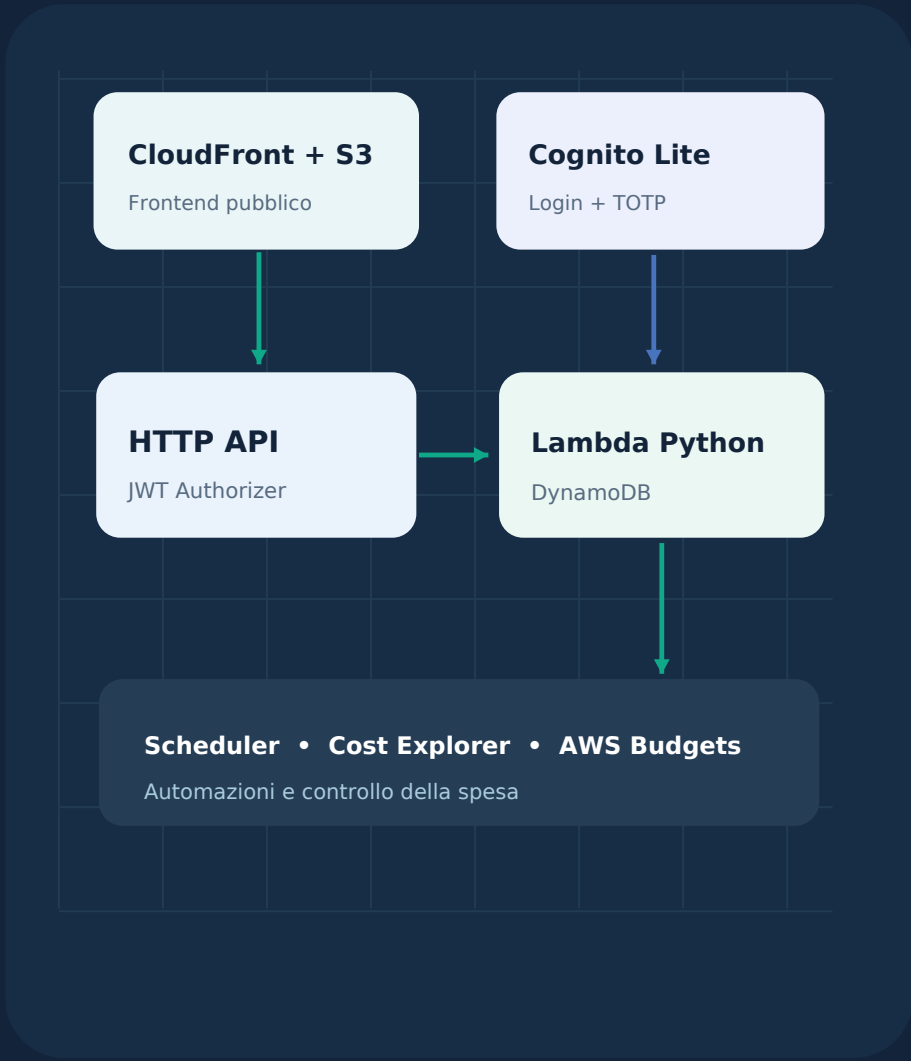
DOCUMENTAZIONE INFRASTRUTTURALE

MONETA

Dashboard personale per la gestione delle finanze

Architettura serverless AWS, accesso Cognito con MFA, dati a Milano e frontend distribuito via CloudFront.



VERSIONE DI RIFERIMENTO

moneta-clean-install

13 ottobre 2026 | Configurazione da repository

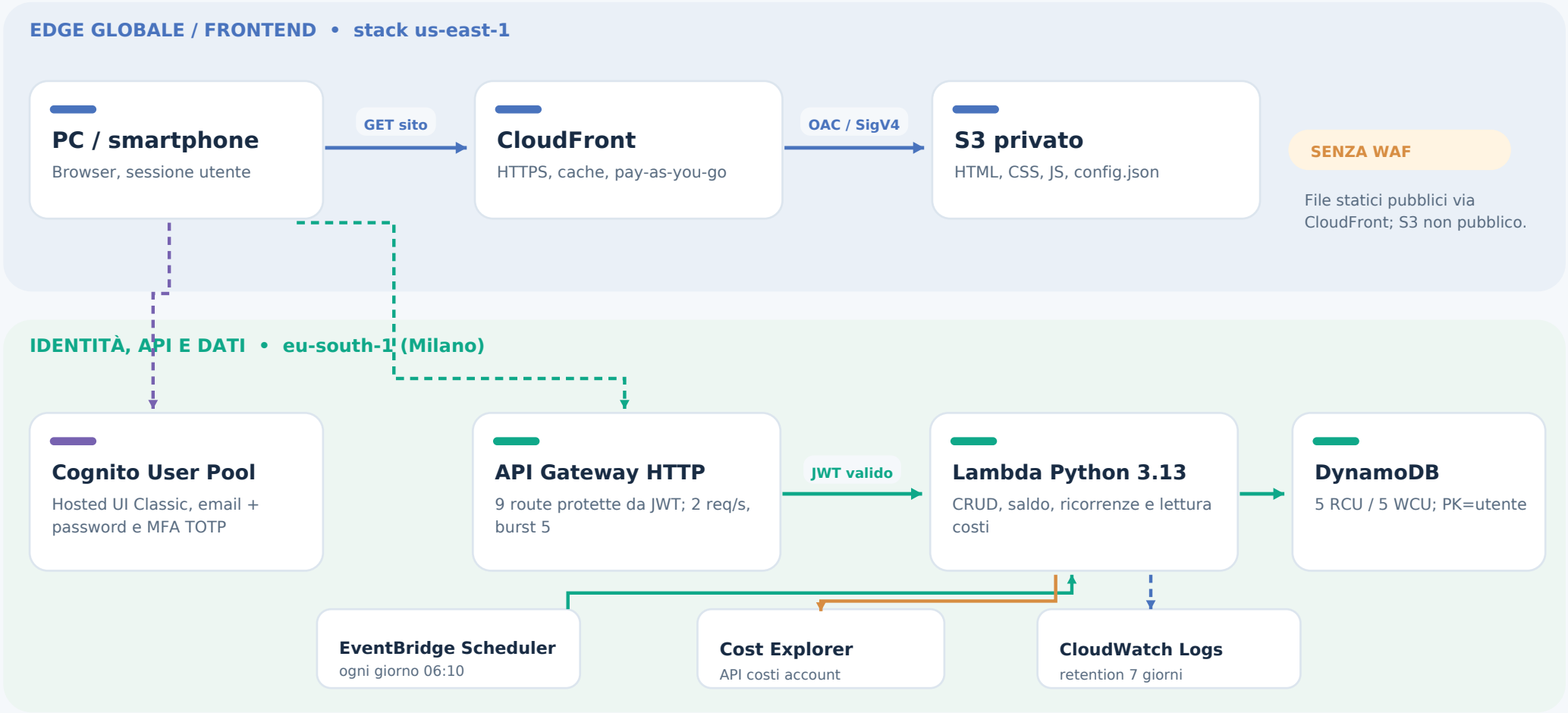
3 STACK

2 REGIONI

MFA OBBLIGATORIA

01 Diagramma infrastrutturale dettagliato

Risorse effettivamente definite nei template Moneta | linee continue: traffico / linee tratteggiate: controllo



SERVIZI TRASVERSALI / OPERATIVITÀ

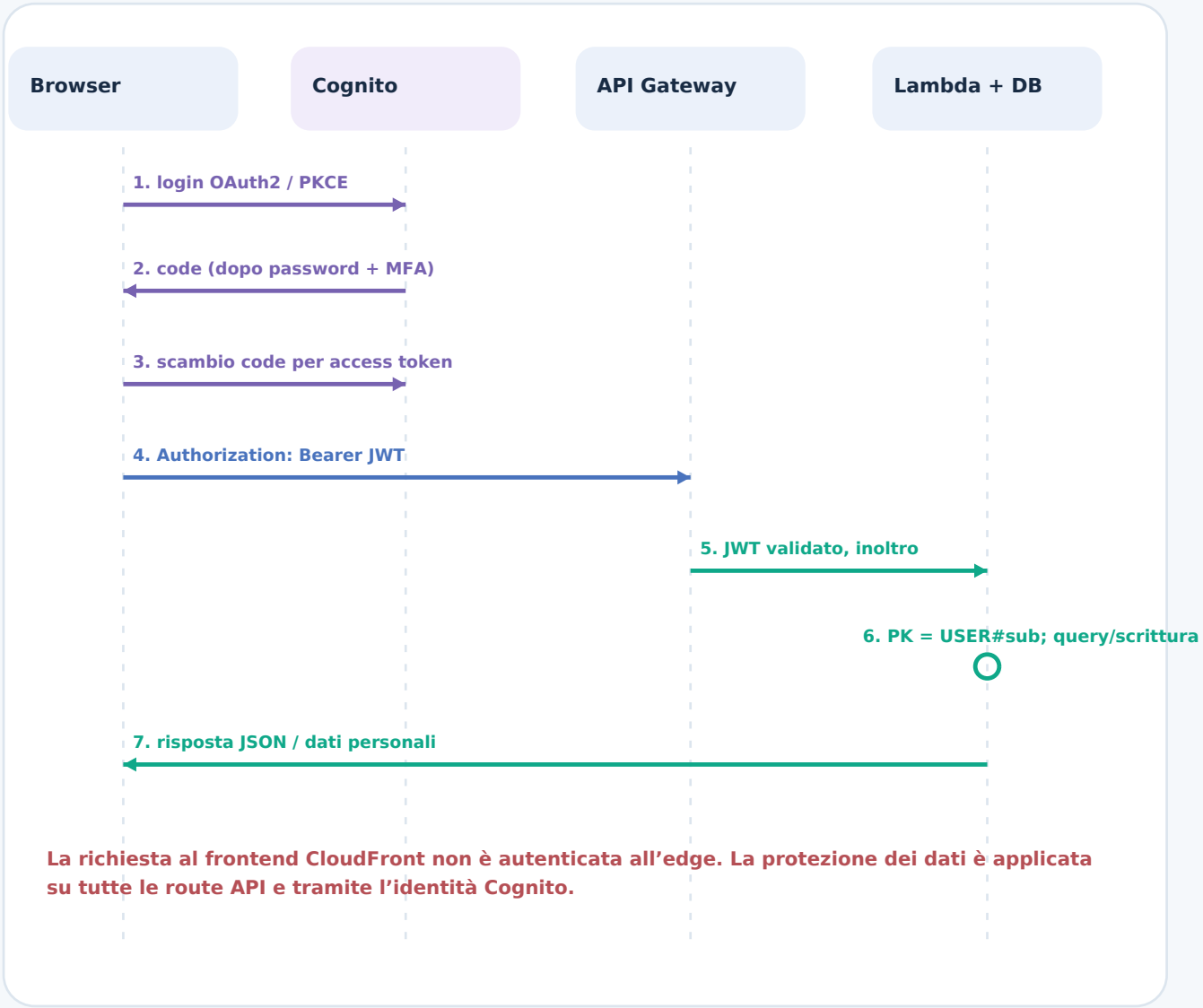
AWS Budgets • moneta-budget
3 USD/mese; email 50 / 75 / 100%

CloudFormation • 3 stack
deploy separato di frontend, backend e budget

GoDaddy / dominio personalizzato
NON ancora configurato nei template

02 Percorso della richiesta e autenticazione

Distinzione essenziale: vedere l’HTML non significa poter leggere le transazioni



La richiesta al frontend CloudFront non è autenticata all’edge. La protezione dei dati è applicata su tutte le route API e tramite l’identità Cognito.

CONTROLLI ATTIVI

- Iscrizione pubblica disabilitata
- Password: minimo 14 caratteri
- MFA software TOTP obbligatoria
- JWT verificato da API Gateway
- Controllo token_use, client_id e sub in Lambda

SUPERFICIE PUBBLICA

CloudFront serve HTML, CSS, JS e configurazione OAuth pubblica. L’endpoint execute-api è raggiungibile da Internet, ma le route applicative richiedono JWT.

CORS non è un controllo di accesso per bot o client non-browser.

AUTORIZZAZIONE DEI DATI

I record finanziari sono partizionati per USER#sub in DynamoDB. L’utente non sceglie arbitrariamente la partizione; la Lambda la deriva dai claim del token.

03 Inventario degli stack CloudFormation

Origine: cloudformation/frontend.yml, backend.yml e budget.yml del pacchetto moneta-clean

STACK / REGIONE	RISORSA	SCOPO E CONFIGURAZIONE
moneta-frontend us-east-1	**S3 WebBucket**	S3 privato, Block Public Access, SSE-S3; Retain
	CloudFront + OAC	HTTPS predefinito, redirect da HTTP; cache; PriceClass_100
	BucketPolicy	Lettura GetObject consentita soltanto alla distribuzione
moneta-backend eu-south-1	**Cognito User Pool**	Piano Lite, email, MFA TOTP ON, client OAuth code + PKCE
	API Gateway v2	HTTP API; 9 route JWT; throttling 2 req/s / burst 5
	Lambda Python 3.13	128 MB, timeout 20 s; IAM per tabella, log e costi AWS
	DynamoDB	Provisioned 5 RCU / 5 WCU; dati cifrati; PITR disattivato
	EventBridge Scheduler	Un job ogni giorno alle 06:10 Europe/Rome
	CloudWatch Logs	Log di esecuzione Lambda, retention 7 giorni
moneta-budget us-east-1	**AWS Budgets**	Budget di account 3 USD/mese, alert email e forecast

REGOLE DI CONSERVAZIONE

Il bucket S3, il User Pool Cognito e la tabella DynamoDB hanno DeletionPolicy: Retain. Eliminare lo stack non elimina automaticamente tali risorse; una pulizia completa richiede passaggi dedicati.

04 Flussi automatici e monitoraggio costi

Due meccanismi indipendenti: automazione dei movimenti e osservabilità della spesa

FLUSSO A • MOVIMENTI RICORRENTI



Una sola schedulazione per tutte le regole. Il job verifica scadenze e genera record con ID deterministico e controllo di esistenza: evita duplicati anche dopo ritentativi.

FLUSSO B • COST EXPLORER

Utente autenticato → GET /costs → JWT Authorizer → Lambda → AWS Cost Explorer. Il risultato viene conservato in DynamoDB fino a 24 ore.

Costo Explorer:

La chiamata API può essere a pagamento. Il pannello mostra il costo dell'intero account, non solo di Moneta.

FLUSSO C • AWS BUDGETS

AWS Budgets controlla la spesa AWS a livello account e invia email alle soglie 50%, 75%, 100% e al 100% previsto.

Avvertenza importante

Budget di 3 USD ≠ blocco della spesa a 3 USD o 4 EUR. CloudFront e gli altri servizi possono continuare a generare costi.

05 Sicurezza, esposizione Internet e rischi

Controlli effettivi nei template e miglioramenti non ancora applicati

GIÀ CONFIGURATO

- Bucket S3 privato; accesso tramite OAC CloudFront
- HTTPS CloudFront con redirect da HTTP
- Cognito: accesso solo utenti creati da amministratore
- Password forte e MFA TOTP obbligatoria
- Route HTTP API protette con JWT Authorizer
- Token e partizione dati verificati in Lambda
- API throttling 2 richieste/s; burst 5
- Log Lambda con retention di 7 giorni

NON PRESENTE / OPZIONALE

- AWS WAF / rate-based rule CloudFront
- Geo restriction CloudFront: solo Italia
- Blocco di CloudFront prima del login Cognito
- VPN privata / verifica del singolo dispositivo
- Certificato ACM per dominio GoDaddy .com
- Backup DynamoDB PITR automatico
- Hard spending cap o arresto automatico dei servizi

SCENARIO: BOT CONTRO CLOUDFRONT

Un bot può richiedere il frontend pubblico senza superare il login. Questo non dà accesso alle transazioni, ma può consumare richieste e traffico della distribuzione. Il modello a consumo non garantisce che la fattura rimanga sotto 4 EUR al mese.

Mitigazioni da valutare: geo restriction (solo se accettabile), allarmi CloudWatch sul traffico, protezione anti-abuso e, se il tetto di costo è inderogabile, architettura a esposizione più limitata. La geo restriction non ferma bot dall’Italia o tramite proxy.

06 Gestione operativa e prossimi passi

Per consultazione futura e manutenzione del repository

PERCORSO DI DEPLOY DEL REPOSITORY

01	**Budget**	`./scripts/deploy_budget.sh EMAIL`	moneta-budget / us-east-1
02	**Template Lambda**	`python3 scripts/sync_lambda.py`	Codice Python incorporato nel backend.yml
03	**Frontend + backend**	`./scripts/deploy.sh`	moneta-frontend → moneta-backend
04	**Autenticazione**	`Crea utente Cognito + attiva TOTP`	User Pool in eu-south-1

DOMINIO PERSONALIZZATO (FUTURO)

Dominio posseduto: ilsitodipatrizio.com, DNS su GoDaddy. Sottodominio previsto: moneta.ilsitodipatrizio.com (da confermare).

Configurazione futura: certificato ACM in us-east-1, CNAME di validazione, alias CloudFront e aggiornamento callback/logout Cognito. Nessun record DNS è richiesto per l'endpoint CloudFront attuale.

NOTE DI UTILIZZO E VERIFICA

Questo documento descrive i template sorgente Moneta conservati nel repository, non un inventario ottenuto interrogando AWS live. Nomi e URL fisici vengono generati al deploy.

Verificare periodicamente: IAM, quote e costi, avvisi budget, test login MFA, log Lambda, esecuzione scheduler, backup JSON e risorse conservate con Retain.